API Security Risk Analysis Report

Prepared By: Anusha Vijaykumar Patil

Role: Security Analyst Intern

Date: 22 February 2026

Project: Cyber Security Task 3 – API Security Risk Analysis

API Tested: JSONPlaceholder (https://jsonplaceholder.typicode.com)

1. Executive Summary

This report presents a read-only API Security Risk Analysis conducted on the public JSONPlaceholder API. The assessment focused on authentication mechanisms, data exposure, input validation, error handling, and response headers. Several potential security risks were identified including unauthenticated access to user data and excessive data exposure. This report outlines risk severity, business impact, and remediation recommendations

2. Scope of Assessment

Clearly mention:

- Only public/demo API tested
- Only read-only GET requests used
- No exploitation performed
- Analysis based on documentation and response inspection
- Tools used: Postman

3. Methodology

Write step-based methodology:

1. Reviewed API documentation
2. Identified available endpoints
3. Sent GET requests using Postman

4. Inspected response headers

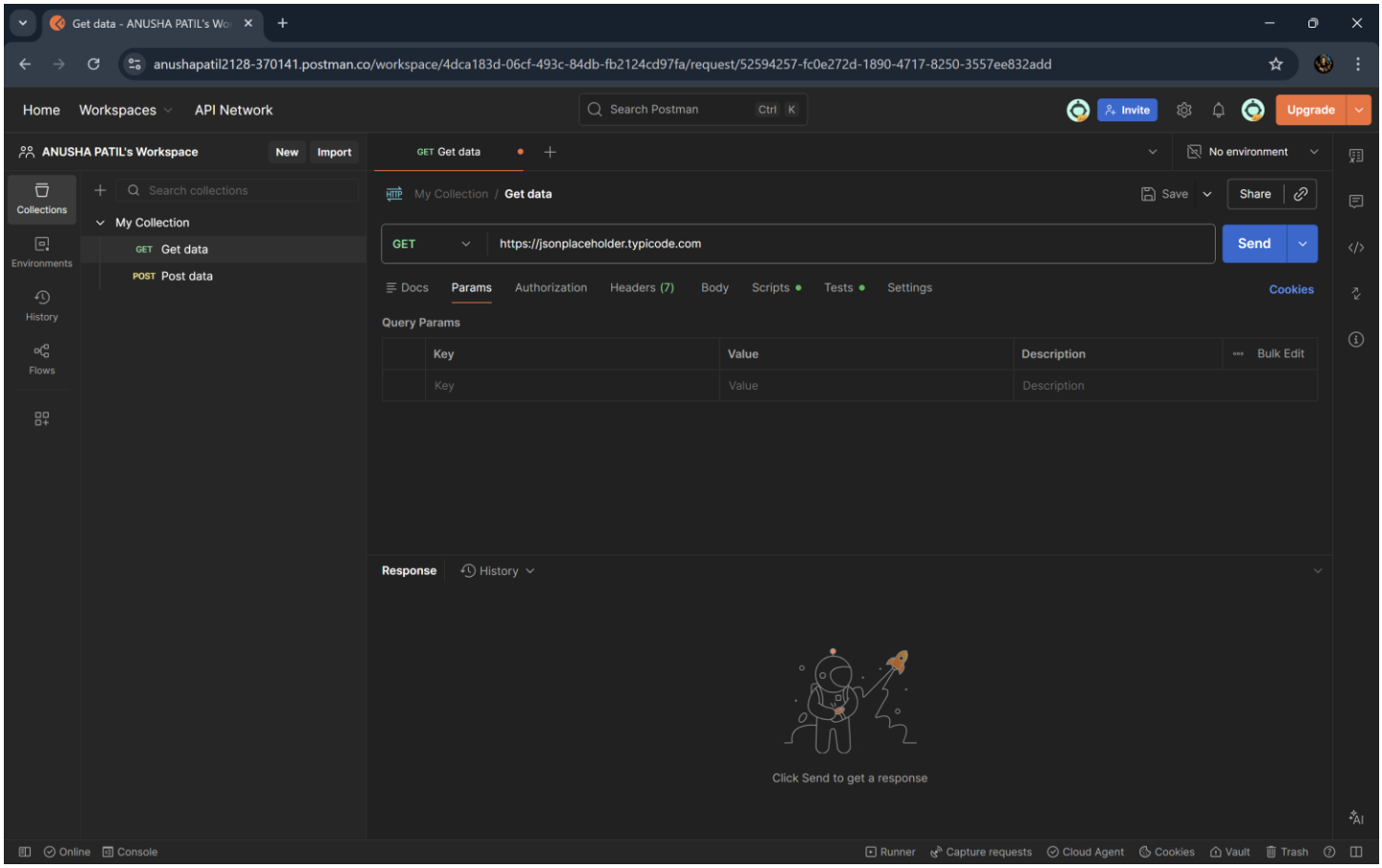
5. Analyzed authentication requirements

6. Tested input validation

7. Observed error handling

8. Assessed potential business risk

- **<u>Postman Tool Interface :</u>**



4. Findings & Risk Analysis

- **Finding 1: Unauthenticated Access to User Data**

- Endpoint: /users

- Severity: Medium

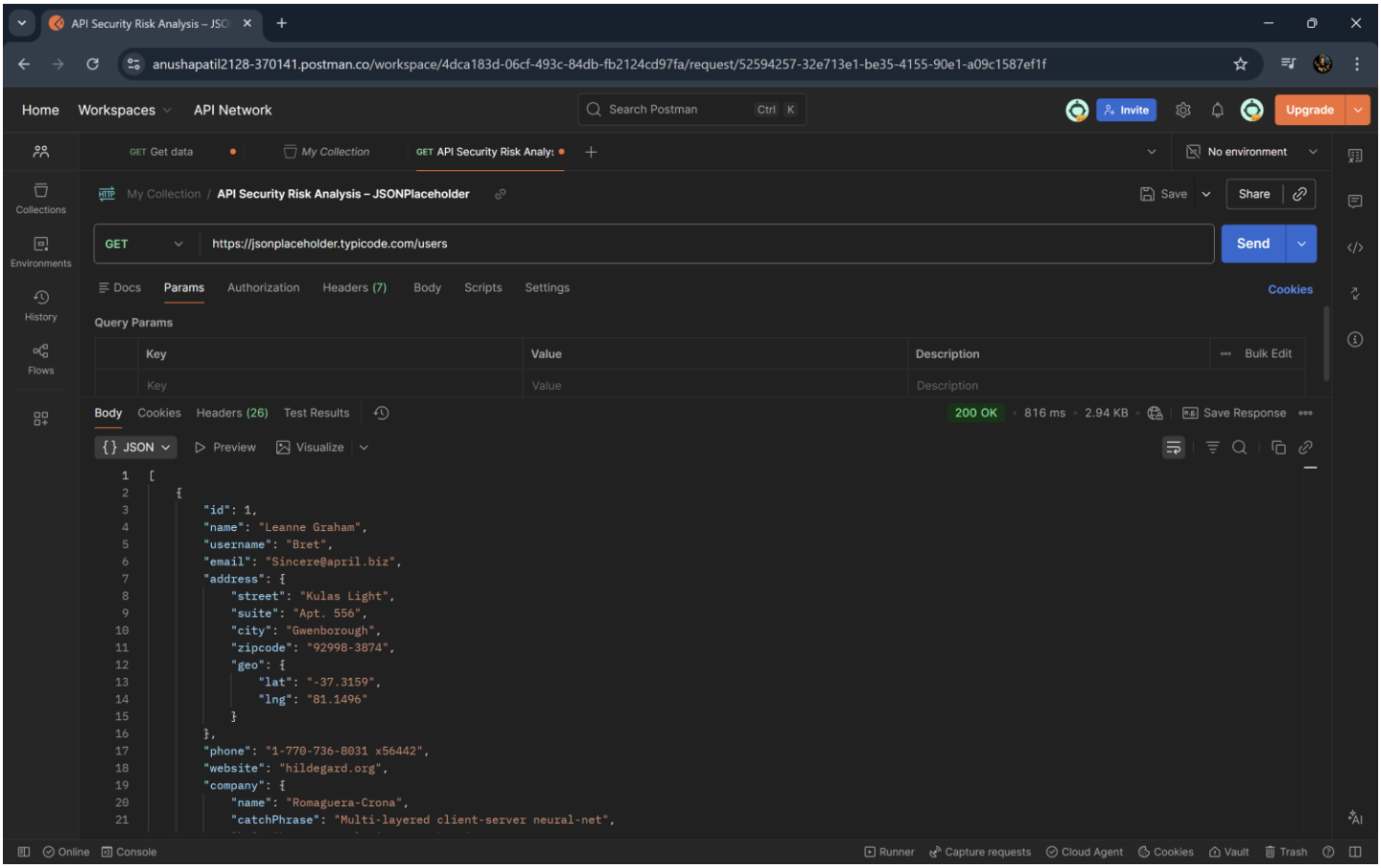
- Risk Type: Missing Authentication

- Description:

  The /users endpoint is publicly accessible without authentication. User information including name, email, address, and phone number can be retrieved without any access control.

- Recommendation:

  Implement authentication mechanisms such as OAuth2 or token-based access control. Apply role-based authorization to restrict access to authorized users only.



Body Description

- **<u>Finding 2: Excessive Data Exposure</u>**

- Endpoint: /users/1

- Severity: Medium

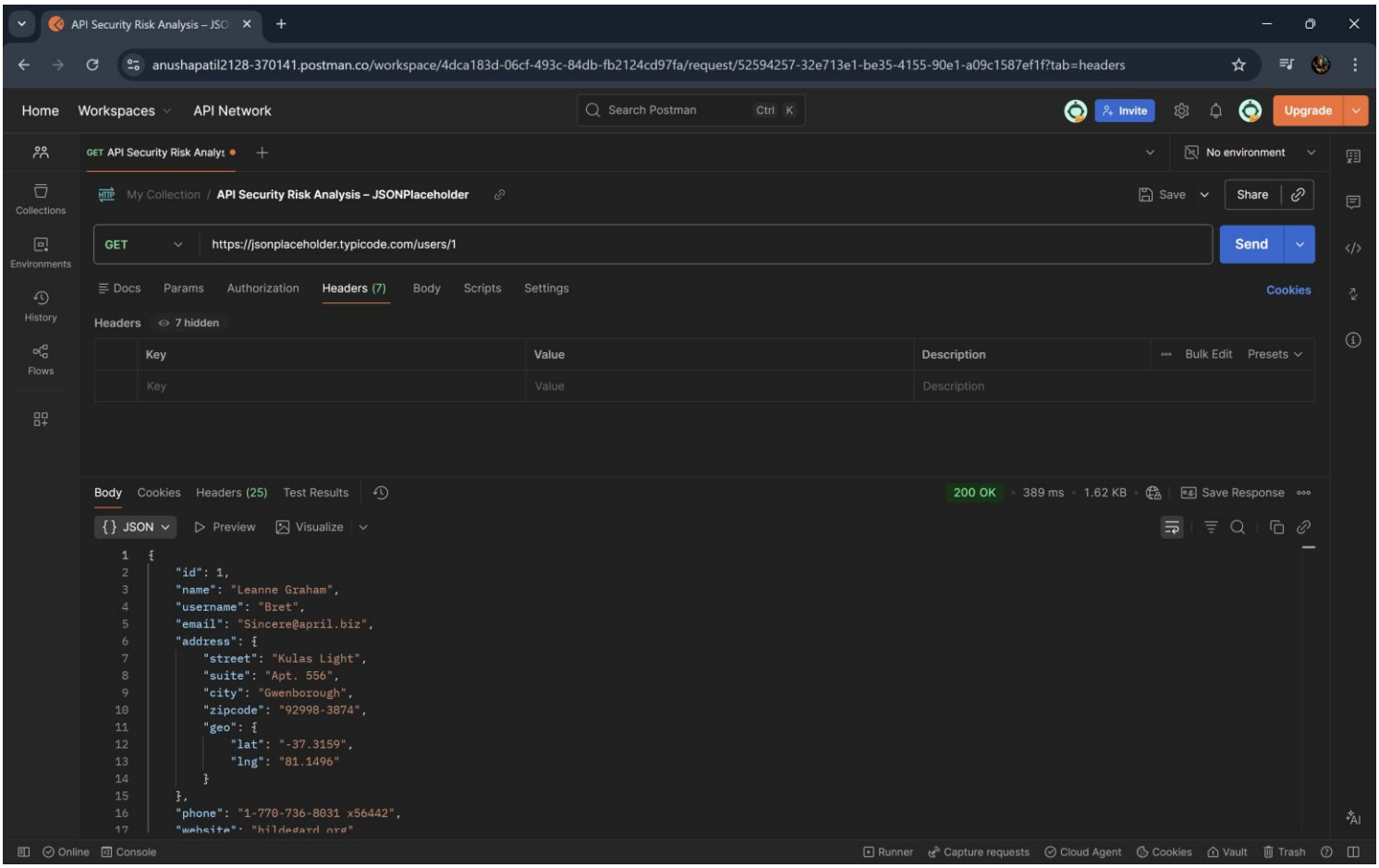
- Risk Type: Missing Authentication

- Description:

  The API response includes detailed user information including address, geographic coordinates, and company details. Not all fields may be necessary for standard client operations.

- Recommendation:

  Apply response filtering to return only required fields. Follow the principle of least privilege and data minimization.



- **Finding 3: Error Handling Behavior**

- Endpoint: /users/99999

- Observed Response: 404 Not Found

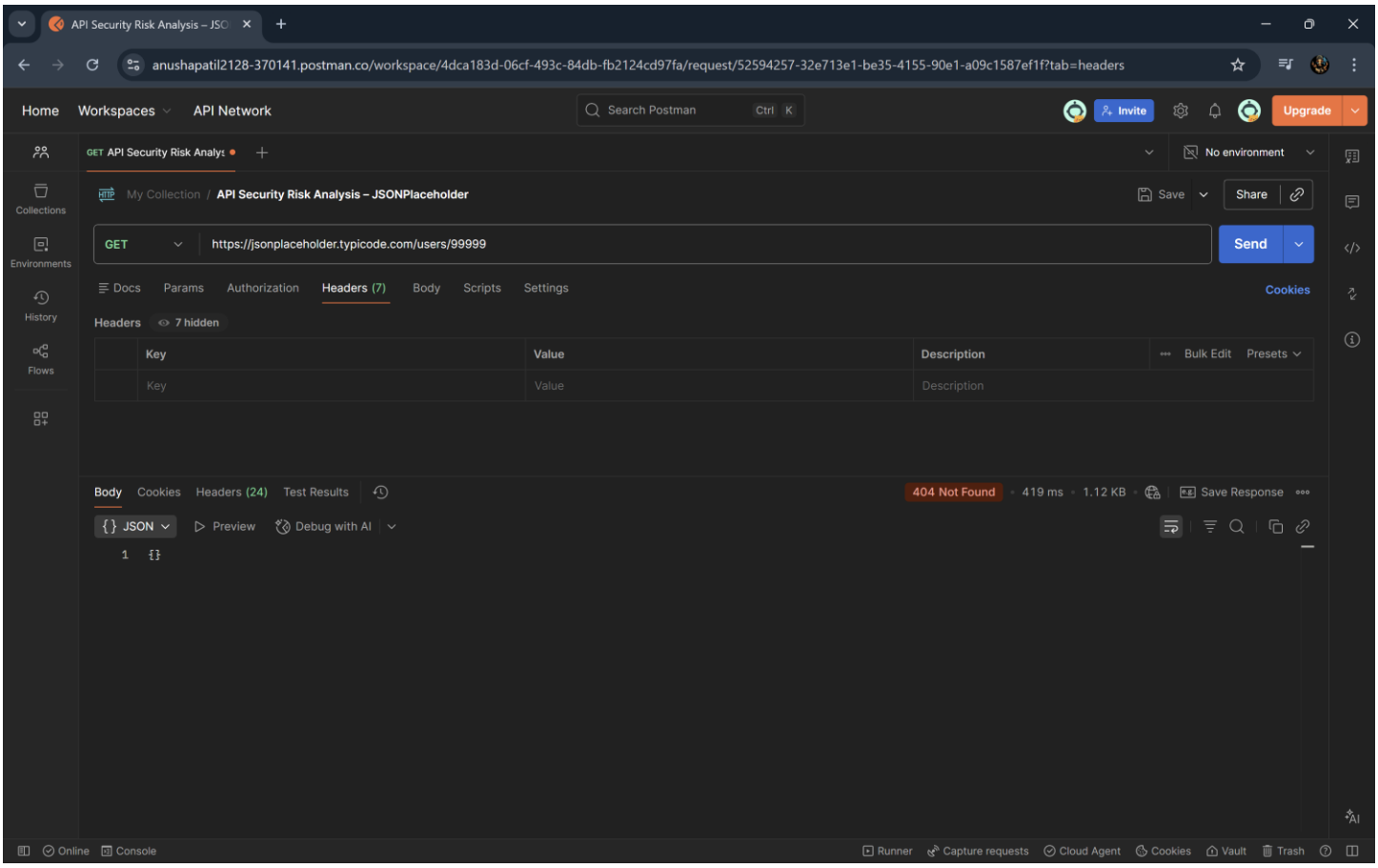
- Severity: Low

- Description:

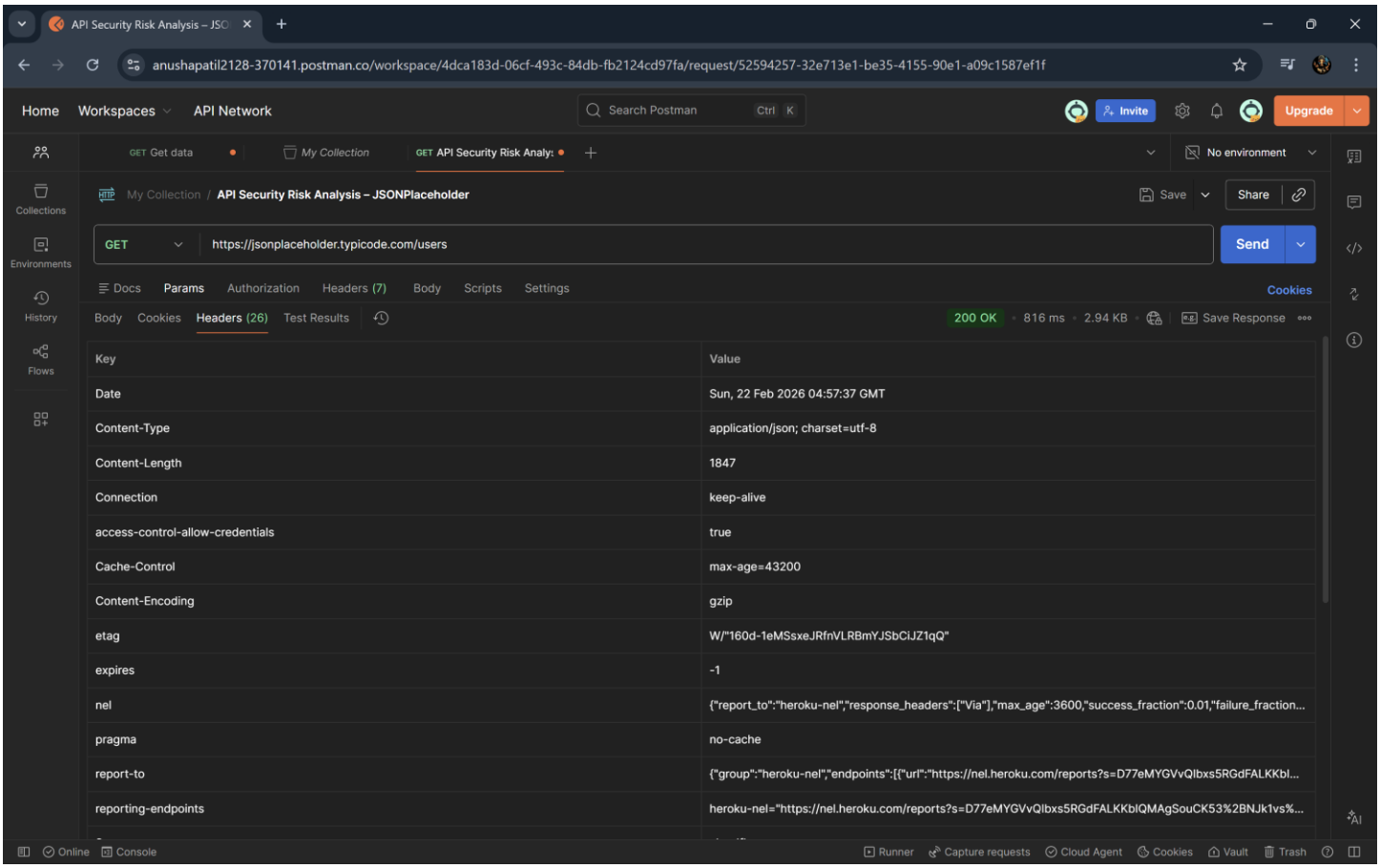
  The API correctly returns a 404 status for non-existent resources. However, error responses are minimal and do not include structured error objects.

- Recommendation:

  Use standardized error responses with structured JSON error formats.



- **Headers Review**



- **Risk Severity Summary Table**

Finding	Severity
Unauthenticated Access	Medium
Excessive Data Exposure	Medium
Error Handling Review	Low

- **Conclusion**

The assessment successfully identified potential security weaknesses without performing exploitation. The findings emphasize the importance of authentication, access control, and data minimization in API-driven SaaS environments.